

**Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО**

Факультет безопасности информационных технологий

Дисциплина:

«Технология обнаружения уязвимостей в автоматизированных системах»

ОТЧЕТ ПО CVSS Score

Выполнили:

Чу Ван Доан, студент группы N3447



(подпись)

Проверил:

к.т.н., доц., Менщиков Александр Алексеевич

(отметка о выполнении)

(подпись)

Санкт-Петербург

2025 г.

1. Вариант задания

Уязвимость в веб-приложении, эксплуатируемая путем отправки запроса от имени неавторизованного пользователя. Она позволяет атакующему читать произвольные файлы на файловой системе.

2. Ход работы

Оценка v4 (CVSS-B): 8.7 / High

Вектор v4: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N

Обоснование по метрикам:

- AV:N (Attack Vector — Network). Эксплуатация идёт сетевым запросом к веб-приложению (HTTP).
- AC:L (Attack Complexity — Low). Достаточно сформировать специальный запрос; редких/хрупких условий нет.
- AT:N (Attack Requirements — None). Нет дополнительных требований к состоянию системы или окружения.
- PR:N (Privileges Required — None). По условию атака выполняется от имени неавторизованного пользователя.
- UI:N (User Interaction — None). Взаимодействие пользователя не требуется — хватает входящего запроса.
- VC:H (Confidentiality impact — High, на уязвимой системе). Возможность чтения произвольных файлов приводит к серьёзной утечке конфиденциальных данных (секреты, ключи, токены, конфиги).
- VI:N / VA:N (Integrity/Availability — None). Модификация/удаление данных и отказ в обслуживании в описании отсутствуют.
- SC:N / SI:N / SA:N (Subsequent System Impacts — None). По базовому описанию затрагивается только уязвимая система; прямого воздействия на последующие системы не заявлено.

Примечания (когда вектор стоит скорректировать):

- Если доступ к уязвимой конечной точке возможен только после входа, используйте PR:L вместо PR:N.
- Если требуются особые предварительные условия, установите AT:P.

- Если чтение файлов гарантированно ведёт к немедленному воздействию на другие системы в рамках той же операции (редко и должно быть подтверждено), тогда оценивайте соответствующие SC/SI/SA.



Common Vulnerability Scoring System Version 4.0 Calculator

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N

Reset

CVSS v4.0 Score: 8.7 / High ⊕

Exploitability Metrics			
Attack Vector (AV):	Network (N)	Adjacent (A)	Local (L)
Attack Complexity (AC):	Low (L)	High (H)	
Attack Requirements (AT):	None (N)	Present (P)	
Privileges Required (PR):	None (N)	Low (L)	High (H)
User Interaction (UI):	None (N)	Passive (P)	Active (A)
Vulnerable System Impact Metrics			
Confidentiality (VC):	High (H)	Low (L)	None (N)
Integrity (VI):	High (H)	Low (L)	None (N)
Availability (VA):	High (H)	Low (L)	None (N)
Subsequent System Impact Metrics			
Confidentiality (SC):	High (H)	Low (L)	None (N)
Integrity (SI):	High (H)	Low (L)	None (N)
Availability (SA):	High (H)	Low (L)	None (N)

Рисунок 1 - CVSS